

EVIDENCIAS Y VALIDACIONES DE SEGURIDAD DE REDES

Objetivo y criterio de validación

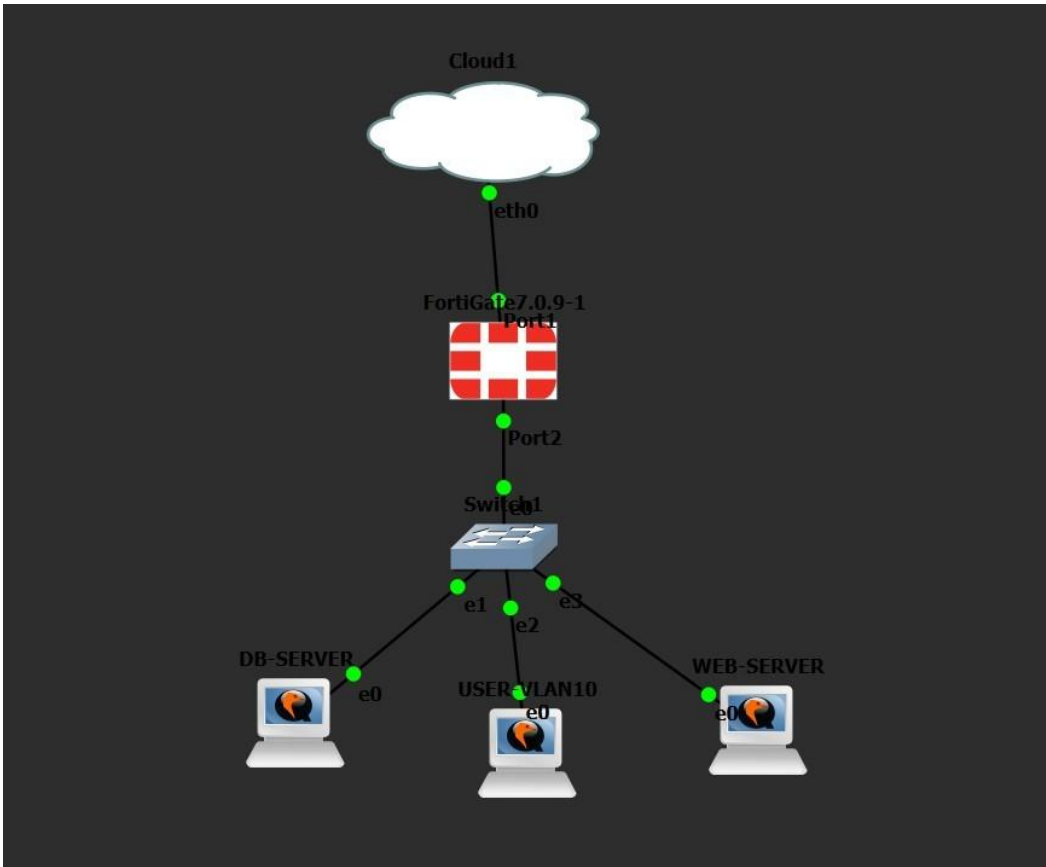
Este documento reúne las evidencias obtenidas durante la implementación del laboratorio. Cada captura se acompaña de una explicación breve de qué requisito valida, cuál fue el resultado observado y cómo debe interpretarse dentro del repositorio GitHub. Las pruebas ofensivas mostradas fueron ejecutadas de forma controlada únicamente contra los equipos del laboratorio propio.

Resumen de resultados

Control / prueba	Resultado
Segmentación VLAN y topología	Validado
Ruta por defecto e Internet/DNS	Validado
USERS → WEB HTTPS	Permitido
USERS → DB TCP/3306	Bloqueado
WEB → DB TCP/3306	Permitido
WEB → DB otros servicios	Bloqueados
File Filter .exe	Bloqueado
Rate limiting HTTPS	Validado (~1.79 Mbps)
SQL Injection	Detectada y descartada
Cuarentena atacante	Validada
SYN flood	Detectado por DoS Policy

Topología, VLAN y enrutamiento

Topología general en GNS3



Qué valida	Arquitectura del laboratorio: Cloud/Internet, FortiGate, switch, USER-VLAN10, WEB-SERVER y DB-SERVER.
Resultado observado	La topología muestra todos los dispositivos y enlaces principales utilizados en la práctica.

Configuración de VLAN en Switch1

Switch1 configuration

General

Name:

Switch1

Console type:

none

Settings

Port:

8

VLAN:

1

Type:

access

QinQ EtherType:

0x8100

Add

Delete

Ports

Port	VLAN	Type	EtherType
0	1	dot1q	
1	30	access	
2	10	access	
3	20	access	
4	999	access	
5	999	access	
6	999	access	
7	999	access	

Reset

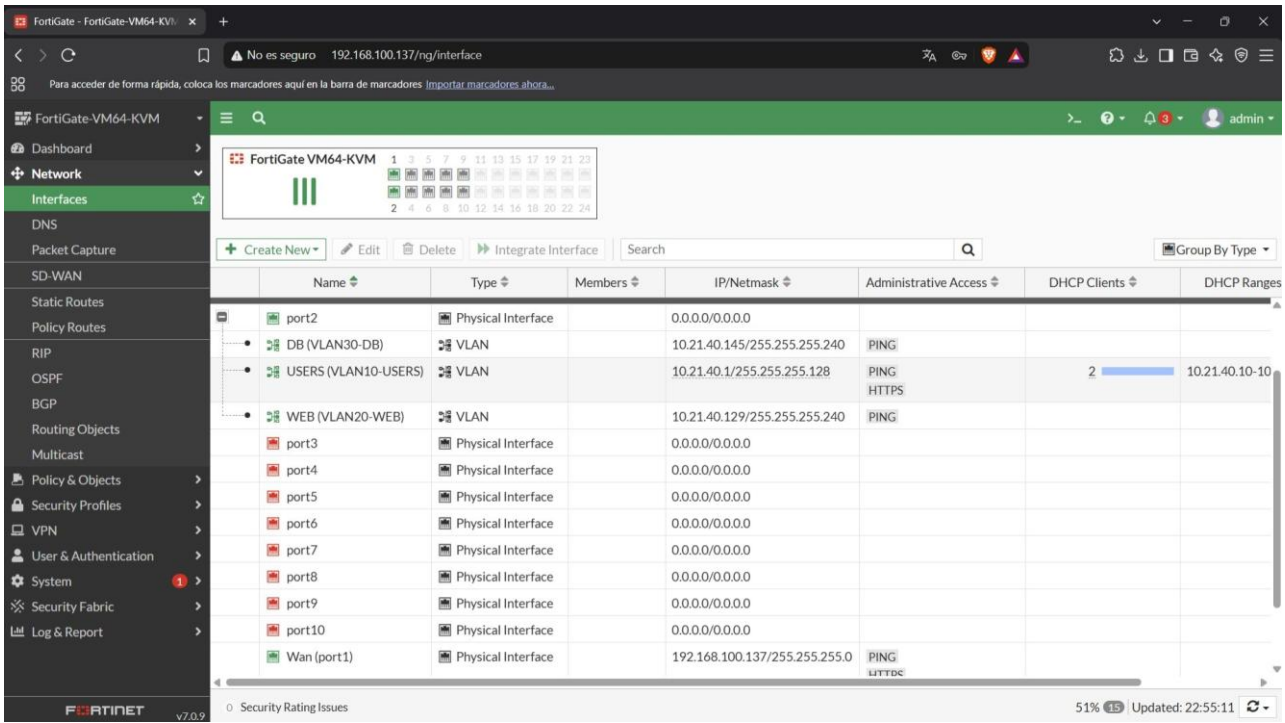
OK

Cancel

Apply

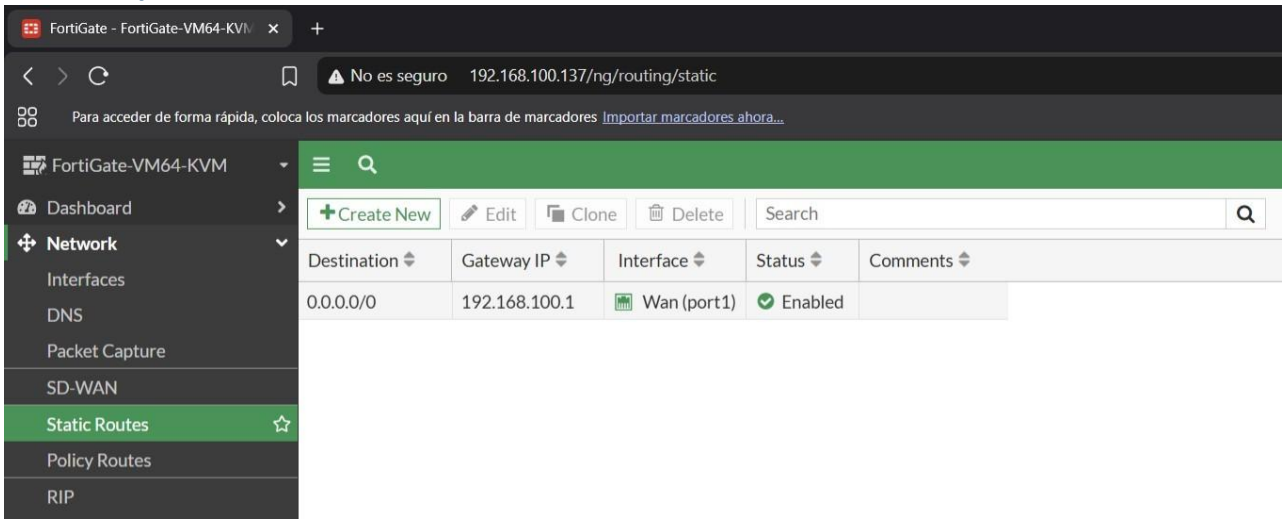
Qué valida	Segmentación de puertos y enlace trunk hacia FortiGate.
Resultado observado	Se observan el trunk 802.1Q y los puertos de acceso para VLAN 10, 20 y 30, además de puertos no utilizados asignados a VLAN 999.

Interfaces y subinterfaces del FortiGate



Qué valida	Configuración L3 de las VLAN internas en FortiGate.
Resultado observado	Se muestran las subinterfaces para USERS, WEB y DB con sus direcciones de gateway.

Ruta estática por defecto



Qué valida	Ruta por defecto requerida para la salida hacia Internet.
Resultado observado	FortiGate tiene 0.0.0.0/0 vía 192.168.100.1 por Wan (port1), en estado Enabled.

Validación de conectividad a Internet y DNS

```

ping -c 4 google.com
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=118 time=35.0 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=117 time=36.5 ms
64 bytes from 8.8.8.8: icmp_seq=3 ttl=117 time=32.2 ms
64 bytes from 8.8.8.8: icmp_seq=4 ttl=117 time=32.2 ms

--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3002ms
rtt min/avg/max/mdev = 32.203/33.976/36.469/1.842 ms
PING google.com (192.178.50.78) 56(84) bytes of data.
64 bytes from tzmiaa-ad-in-f14.1e100.net (192.178.50.78): icmp_seq=1 ttl=118 time=33.5 ms
64 bytes from tzmiaa-ad-in-f14.1e100.net (192.178.50.78): icmp_seq=2 ttl=117 time=32.2 ms
64 bytes from tzmiaa-ad-in-f14.1e100.net (192.178.50.78): icmp_seq=3 ttl=117 time=91.0 ms
64 bytes from tzmiaa-ad-in-f14.1e100.net (192.178.50.78): icmp_seq=4 ttl=117 time=34.0 ms

--- google.com ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3006ms
rtt min/avg/max/mdev = 32.184/47.682/91.016/25.027 ms
carlos2140@carlos2140:~$

```

Qué valida	Salida a Internet desde USER-VLAN10 y resolución DNS.
Resultado observado	Los pings a 8.8.8.8 y google.com obtienen 4/4 respuestas y 0% de pérdida.

Políticas de firewall y segmentación

Políticas principales del firewall

FortiGate - FortiGate-VM64-KVM										
Dashboard										
Network										
Policy & Objects										
Firewall Policy										
IPV4 DoS Policy										
Addresses										
Internet Service Database										
Services										
Schedules										
Virtual IPs										
IP Pools										
Protocol Options										
Traffic Shaping										
Security Profiles										
VPN										
User & Authentication										
System										
Security Fabric										
Log & Report										

Name	Source	Destination	Schedule	Service	Action	NAT	Security Profiles	Log	Bytes
DB (VLAN30-DB) → Wan (port1)	DB-SERVER	all	always	ALL	ACCEPT	Enabled	no-inspection	All	3.92 kB
USERS (VLAN10-USERS) → DB (VLAN30-DB)	NET-USERS	DB-SERVER	always	MYSQL	DENY			All	0 B
USERS (VLAN10-USERS) → Wan (port1)	NET-USERS	all	always	ALL	ACCEPT	Enabled	deep-inspection BLOCK-EXE	All	3.78 MB
USERS (VLAN10-USERS) → WEB (VLAN20-WEB)	NET-USERS	WEB-SERVER	always	HTTPS	ACCEPT	Disabled	IPS-SQLI-QUARANTINE custom-deep-inspection BLOCK-EXE	All	13.29 MB
WEB (VLAN20-WEB) → DB (VLAN30-DB)	WEB-SERVER	DB-SERVER	always	MYSQL	ACCEPT	Disabled	no-inspection	All	0 B
WEB (VLAN20-WEB) → Wan (port1)	WEB-SERVER	all	always	ALL	ACCEPT	Enabled	no-inspection	All	1.84 MB
Implicit									

Qué valida	Aplicación del principio de mínimo privilegio entre USERS, WEB, DB e Internet.
Resultado observado	La lista contiene las políticas de acceso a Internet, denegación USERS→DB, permiso USERS→WEB HTTPS y permiso WEB→DB MySQL.

Validaciones desde USER-VLAN10

USER-VLAN10: DHCP y tabla de rutas

```
carlos2140@carlos2140:~$ ip a show ens3
ip route
2: ens3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 0c:42:7a:a7:00:00 brd ff:ff:ff:ff:ff:ff
    altname enp0s3
    inet 10.21.40.11/25 metric 100 brd 10.21.40.127 scope global dynamic ens3
        valid_lft 581463sec preferred_lft 581463sec
    inet6 fe80::e42:7aff:fea7:0/64 scope link
        valid_lft forever preferred_lft forever
default via 10.21.40.1 dev ens3 proto dhcp src 10.21.40.11 metric 100
1.1.1.1 via 10.21.40.1 dev ens3 proto dhcp src 10.21.40.11 metric 100
8.8.8.8 via 10.21.40.1 dev ens3 proto dhcp src 10.21.40.11 metric 100
10.21.40.0/25 dev ens3 proto kernel scope link src 10.21.40.11 metric 100
10.21.40.1 dev ens3 proto dhcp scope link src 10.21.40.11 metric 100
carlos2140@carlos2140:~$
```

Qué valida	Asignación dinámica de IP al usuario y gateway de la VLAN 10.
Resultado observado	El cliente recibe 10.21.40.11/25 y utiliza 10.21.40.1 como gateway.

USERS → WEB por HTTPS permitido

```
* Trying 10.21.40.130:443...
* Connected to 10.21.40.130 (10.21.40.130) port 443
* ALPN: curl offers h2,http/1.1
* TLSv1.3 (OUT), TLS handshake, Client hello (1):
* TLSv1.3 (IN), TLS handshake, Server hello (2):
* TLSv1.3 (IN), TLS handshake, Encrypted Extensions (8):
* TLSv1.3 (IN), TLS handshake, Certificate (11):
* TLSv1.3 (IN), TLS handshake, CERT verify (15):
* TLSv1.3 (IN), TLS handshake, Finished (20):
* TLSv1.3 (OUT), TLS change cipher, Change cipher spec (1):
* TLSv1.3 (OUT), TLS handshake, Finished (20):
* SSL connection using TLSv1.3 / TLS_AES_256_GCM_SHA384 / X25519 / id-ecPublicKey
* ALPN: server accepted http/1.1
* Server certificate:
* subject: C=US; ST=California; L=Sunnyvale; O=Fortinet; OU=FortiGate; CN=10.21.40.130; emailAddress=support@fortinet.com
* start date: Sep 26 01:05:09 2026 GMT
* expire date: Sep 25 07:56:01 2036 GMT
* issuer: C=US; ST=California; L=Sunnyvale; O=Fortinet; OU=Certificate Authority; CN=FGVMEVOJQOKJJXAF; emailAddress=support@fortinet.com
* SSL certificate verify result: unable to get local issuer certificate (20), continuing anyway.
* Certificate level 0: Public key type EC/prime256v1 (256/128 Bits/secBits), signed using sha256WithRSAEncryption
* using HTTP/1.x
> GET / HTTP/1.1
> Host: 10.21.40.130
> User-Agent: curl/8.5.0
> Accept: */*
>
* TLSv1.3 (IN), TLS handshake, NewSession Ticket (4):
* TLSv1.3 (IN), TLS handshake, NewSession Ticket (4):
* old SSL session ID is stale, removing
< HTTP/1.1 200 OK
< Date: Sat, 26 Sep 2026 06:27:26 GMT
< Server: Apache/2.4.58 (Ubuntu)
< Last-Modified: Fri, 25 Sep 2026 21:57:54 GMT
< ETag: "ee-65c55cef39285"
< Accept-Ranges: bytes
< Content-Length: 238
< Vary: Accept-Encoding
< Content-Type: text/html
<
<!DOCTYPE html>
<html>
<head>
  <title>Laboratorio Seguridad de Redes</title>
</head>
<body>
  <h1>WEB-SERVER - Seguridad de Redes</h1>
  <p>Matrícula: 2025-2140</p>
  <p>Servidor HTTPS protegido por FortiGate</p>
</body>
</html>
* Connection #0 to host 10.21.40.130 left intact
carlos2140@carlos2140:~$
```

Qué valida	Política ALLOW-USERS-TO-WEB-HTTPS.
Resultado observado	La conexión TLS hacia 10.21.40.130:443 se completa y el servidor devuelve la página del laboratorio.

USERS → WEB por HTTP/80 no permitido

```
carlos2140@carlos2140:~$ nc -vz -w 3 10.21.40.130 80
nc: connect to 10.21.40.130 port 80 (tcp) timed out: Operation now in progress
carlos2140@carlos2140:~$
```

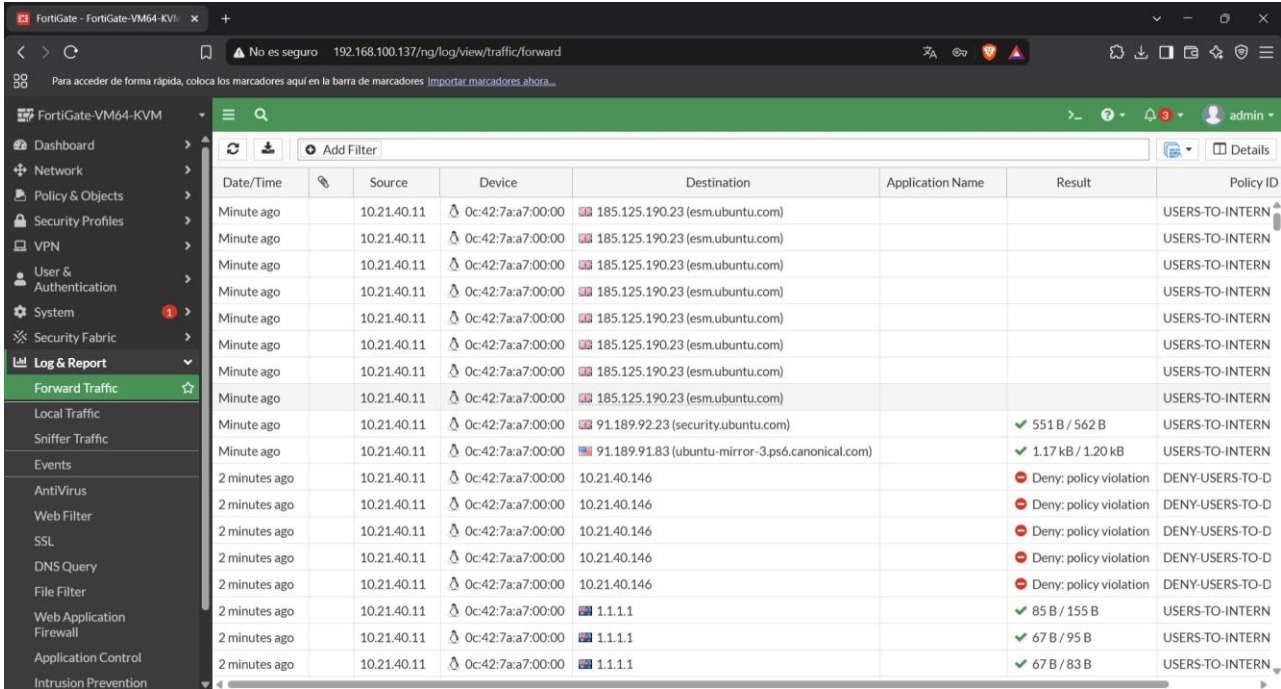
Qué valida	Restricción del acceso al WEB-SERVER a HTTPS.
Resultado observado	La prueba a TCP/80 no establece conexión.

USERS → DB:3306 bloqueado

```
nc: connect to 10.21.40.130 port 80 (tcp) timed out: Operation now in progress
carlos2140@carlos2140:~$ nc -vz -w 5 10.21.40.146 3306
nc: connect to 10.21.40.146 port 3306 (tcp) timed out: Operation now in progress
carlos2140@carlos2140:~$
```

Qué valida	Política DENY-USERS-TO-DB-MYSQL.
Resultado observado	El intento desde USER hacia 10.21.40.146:3306 expira sin conexión.
Comentario para GitHub	Esta evidencia demuestra que los usuarios no tienen acceso directo a MariaDB.

Log de denegación USERS → DB



The screenshot shows the FortiGate web interface with the 'Log & Report' menu open and 'Forward Traffic' selected. The log table displays several entries where traffic from internal hosts (10.21.40.11) to the database server (185.125.190.23) was denied. The 'Result' column shows 'Deny: policy violation' and the 'Policy ID' is 'USERS-TO-INTERN'. Some entries show successful connections to other destinations like security.ubuntu.com and ubuntu-mirror-3.ps6.canonical.com.

Date/Time	Source	Device	Destination	Application Name	Result	Policy ID
Minute ago	10.21.40.11	0c:42:7a:a7:00:00	185.125.190.23 (esm.ubuntu.com)			USERS-TO-INTERN
Minute ago	10.21.40.11	0c:42:7a:a7:00:00	185.125.190.23 (esm.ubuntu.com)			USERS-TO-INTERN
Minute ago	10.21.40.11	0c:42:7a:a7:00:00	185.125.190.23 (esm.ubuntu.com)			USERS-TO-INTERN
Minute ago	10.21.40.11	0c:42:7a:a7:00:00	185.125.190.23 (esm.ubuntu.com)			USERS-TO-INTERN
Minute ago	10.21.40.11	0c:42:7a:a7:00:00	185.125.190.23 (esm.ubuntu.com)			USERS-TO-INTERN
Minute ago	10.21.40.11	0c:42:7a:a7:00:00	185.125.190.23 (esm.ubuntu.com)			USERS-TO-INTERN
Minute ago	10.21.40.11	0c:42:7a:a7:00:00	185.125.190.23 (esm.ubuntu.com)			USERS-TO-INTERN
Minute ago	10.21.40.11	0c:42:7a:a7:00:00	185.125.190.23 (esm.ubuntu.com)			USERS-TO-INTERN
Minute ago	10.21.40.11	0c:42:7a:a7:00:00	91.189.92.23 (security.ubuntu.com)		✓ 551 B / 562 B	USERS-TO-INTERN
Minute ago	10.21.40.11	0c:42:7a:a7:00:00	91.189.91.83 (ubuntu-mirror-3.ps6.canonical.com)		✓ 1.17 kB / 1.20 kB	USERS-TO-INTERN
2 minutes ago	10.21.40.11	0c:42:7a:a7:00:00	10.21.40.146		Deny: policy violation	DENY-USERS-TO-D
2 minutes ago	10.21.40.11	0c:42:7a:a7:00:00	10.21.40.146		Deny: policy violation	DENY-USERS-TO-D
2 minutes ago	10.21.40.11	0c:42:7a:a7:00:00	10.21.40.146		Deny: policy violation	DENY-USERS-TO-D
2 minutes ago	10.21.40.11	0c:42:7a:a7:00:00	10.21.40.146		Deny: policy violation	DENY-USERS-TO-D
2 minutes ago	10.21.40.11	0c:42:7a:a7:00:00	10.21.40.146		Deny: policy violation	DENY-USERS-TO-D
2 minutes ago	10.21.40.11	0c:42:7a:a7:00:00	1.1.1.1		✓ 85 B / 155 B	USERS-TO-INTERN
2 minutes ago	10.21.40.11	0c:42:7a:a7:00:00	1.1.1.1		✓ 67 B / 95 B	USERS-TO-INTERN
2 minutes ago	10.21.40.11	0c:42:7a:a7:00:00	1.1.1.1		✓ 67 B / 83 B	USERS-TO-INTERN

Qué valida	Registro de la política de bloqueo hacia la base de datos.
Resultado observado	FortiGate registra sesiones del usuario hacia el DB-SERVER con acción de denegación.
Comentario para GitHub	La captura aporta evidencia desde el firewall, no solamente desde el cliente.

Validaciones WEB-SERVER → DB-SERVER

WEB → DB por TCP/3306 permitido

```
carlos2140@web-server:~$ nc -vz 10.21.40.146 3306
Connection to 10.21.40.146 3306 port [tcp/mysql] succeeded!
carlos2140@web-server:~$
```

Qué valida	Política ALLOW-WEB-TO-DB-MYSQL.
Resultado observado	La prueba nc desde WEB-SERVER confirma que 10.21.40.146:3306 está accesible.

Consulta MariaDB desde WEB-SERVER

```
carlos2140@web-server:~$ nc -vz 10.21.40.146 3306
Connection to 10.21.40.146 3306 port [tcp/mysql] succeeded!
carlos2140@web-server:~$ mysql -h 10.21.40.146 \
-u webapp \
-p \
-e "SELECT * FROM laboratorio.prueba;"
Enter password:
+----+-----+
| id | mensaje |
+----+-----+
| 1 | Conexion WEB-DB funcionando |
+----+-----+
carlos2140@web-server:~$
```

Qué valida	Funcionamiento real de la conexión de aplicación WEB→DB.
Resultado observado	El cliente MariaDB obtiene el registro “Conexion WEB-DB funcionando” de laboratorio.prueba.

WEB → DB: otros servicios bloqueados

```
carlos2140@web-server:~$ nc -vz -w 3 10.21.40.146 22
nc -vz -w 3 10.21.40.146 80
nc: connect to 10.21.40.146 port 22 (tcp) timed out: Operation now in progress
nc: connect to 10.21.40.146 port 80 (tcp) timed out: Operation now in progress
carlos2140@web-server:~$ ping -c 4 10.21.40.146
PING 10.21.40.146 (10.21.40.146) 56(84) bytes of data.

--- 10.21.40.146 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3060ms
```

Qué valida	Mínimo privilegio entre el servidor web y la base de datos.
Resultado observado	Las pruebas a TCP/22, TCP/80 e ICMP no obtienen respuesta.

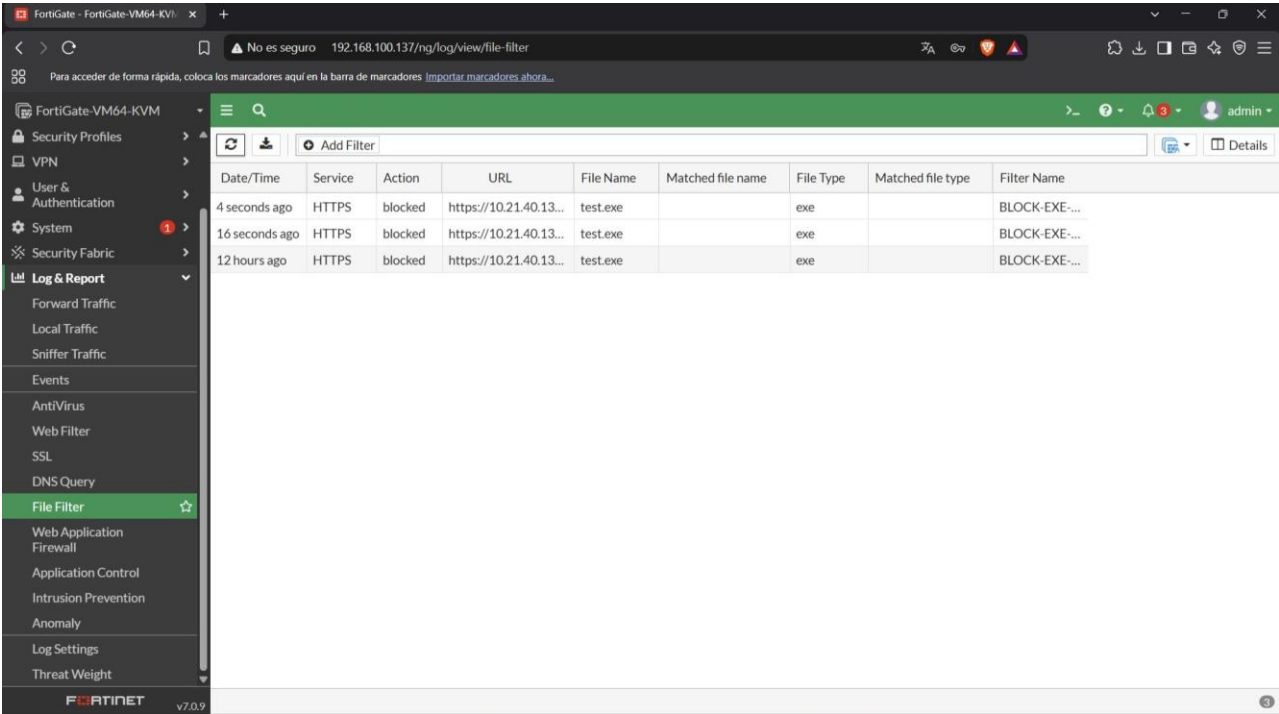
Bloqueo de archivos ejecutables

Intento de descarga de archivo .exe

```
https://10.21.40.130/test.exe
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload    Total   Spent    Left   Speed
 99 1666k    99 1664k    0     0 4695k      0 --:--:-- --:--:-- --:--:-- 4700k
curl: (56) Recv failure: Connection reset by peer
carlos2140@carlos2140:~$ ls -lh /tmp/test.exe
-rw-rw-r-- 1 carlos2140 carlos2140 1.7M Sep 26 06:40 /tmp/test.exe
carlos2140@carlos2140:~$
```

Qué valida	Prueba de usuario contra el File Filter de FortiGate.
Resultado observado	La descarga de test.exe es interrumpida/restablecida y no se completa normalmente.

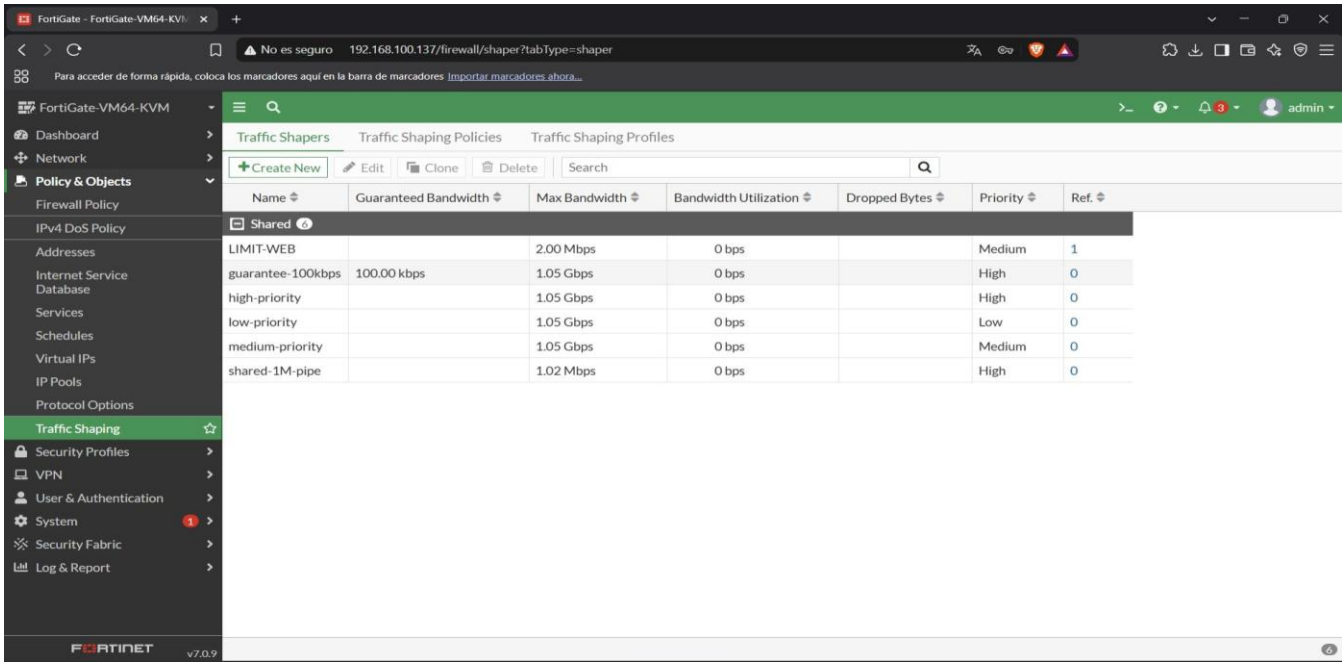
File Filter: ejecutable bloqueado



Qué valida	Perfil BLOCK-EXE aplicado al tráfico HTTPS
Resultado observado	FortiGate registra test.exe, tipo exe, con acción blocked.

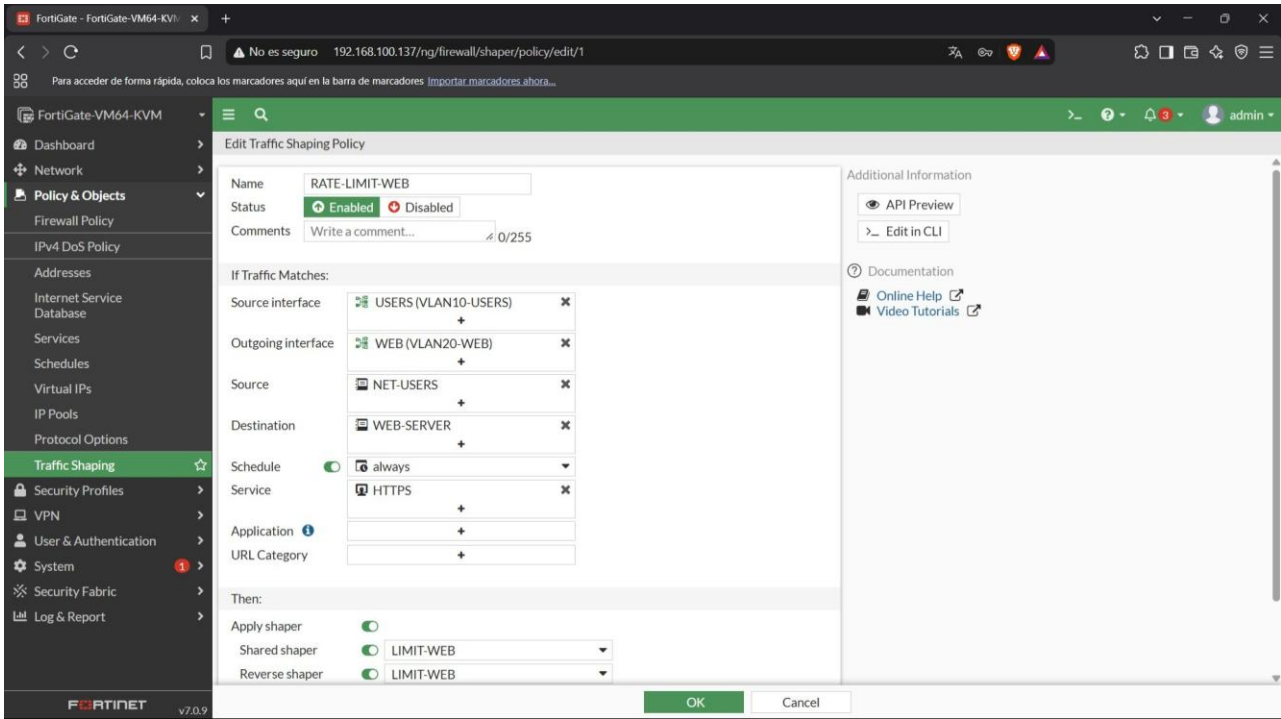
Rate Limiting

Objeto Traffic Shaper LIMIT-WEB



Qué valida	Configuración del límite de ancho de banda.
Resultado observado	LIMIT-WEB está configurado como shaper compartido con máximo de 2000 Kbps.

Política RATE-LIMIT-WEB con shaper directo e inverso



Qué valida	Aplicación efectiva del Traffic Shaper a la sesión HTTPS y a su tráfico de retorno.
Resultado observado	La política utiliza LIMIT-WEB como Shared shaper y también como Reverse shaper para el flujo USERS↔WEB.

Validación corregida de Rate Limiting

```

round-trip min/avg/max = 1.8/13.3/1004.6 ms
carlos2140@carlos2140:~$ curl -k \
-o /dev/null \
-w "Velocidad: %{speed_download} bytes/s\nTiempo: %{time_total} segundos\n" \
https://10.21.40.130/prueba-10mb.bin
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total     Spent    Left     Speed
100 10.0M  100 10.0M    0     0  218k      0  0:00:46  0:00:46 --:--:-- 248k
Velocidad: 223796 bytes/s
Tiempo: 46.853928 segundos
carlos2140@carlos2140:~$

```

Qué valida	Comprobación práctica del límite de 2 Mbps.
Resultado observado	La descarga de 10 MB obtiene 223,796 bytes/s y tarda 46.85 s, equivalente aproximadamente a 1.79 Mbps.

DPI, IPS y SQL Injection

Sensor IPS para SQL Injection

IPS Signatures and Filters

+ Create New Edit Delete			
Details	Exempt IPs	Action	Packet Logging
HTTP.URI.SQL.Injection	0	 Quarantine (Expires 5 Minute(s))	 Enabled
1			

Qué valida	Configuración de la firma HTTP.URI.SQL.Injection con cuarentena.
Resultado observado	La firma está configurada con Action=Quarantine, expiración de 5 minutos y Packet Logging habilitado.

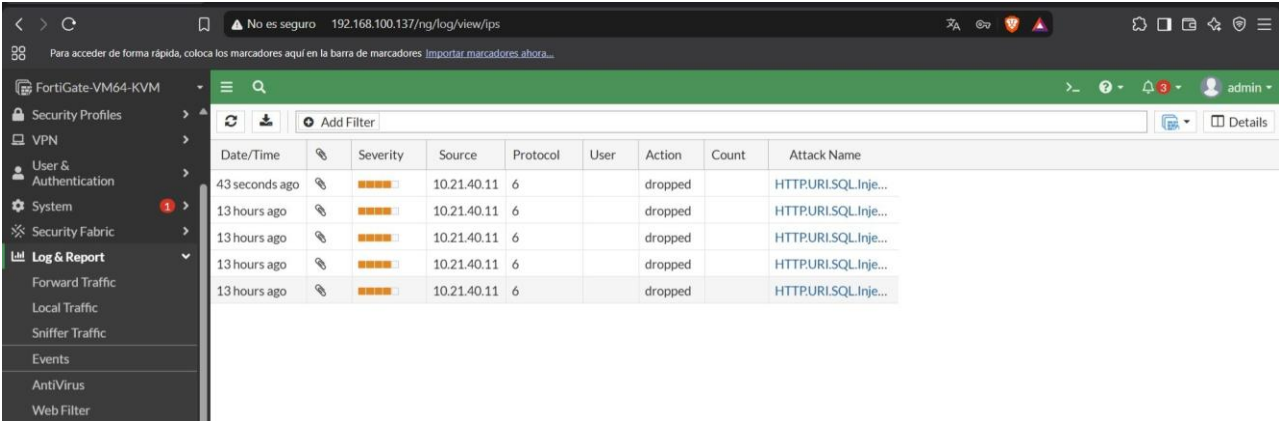
Ejecución del payload de SQL Injection

```
carlos2140@carlos2140:~$ curl -k \
--connect-timeout 5 \
--max-time 15 \
"https://10.21.40.130/?id=1%27%20OR%20%271%27=%271--%20"
curl: (28) Operation timed out after 15002 milliseconds with 0 bytes received
carlos2140@carlos2140:~$
```

Figura 21. Ejecución del payload de SQL Injection.

Qué valida	Prueba controlada contra el WEB-SERVER del laboratorio.
Resultado observado	La solicitud maliciosa no completa una respuesta normal.

IPS: SQL Injection detectada y descartada



Qué valida	Detección y bloqueo del ataque por FortiGate.
Resultado observado	El log de Intrusion Prevention registra la firma HTTP.URI.SQL.Injection y la acción dropped.

Perfiles de seguridad aplicados a USERS → WEB

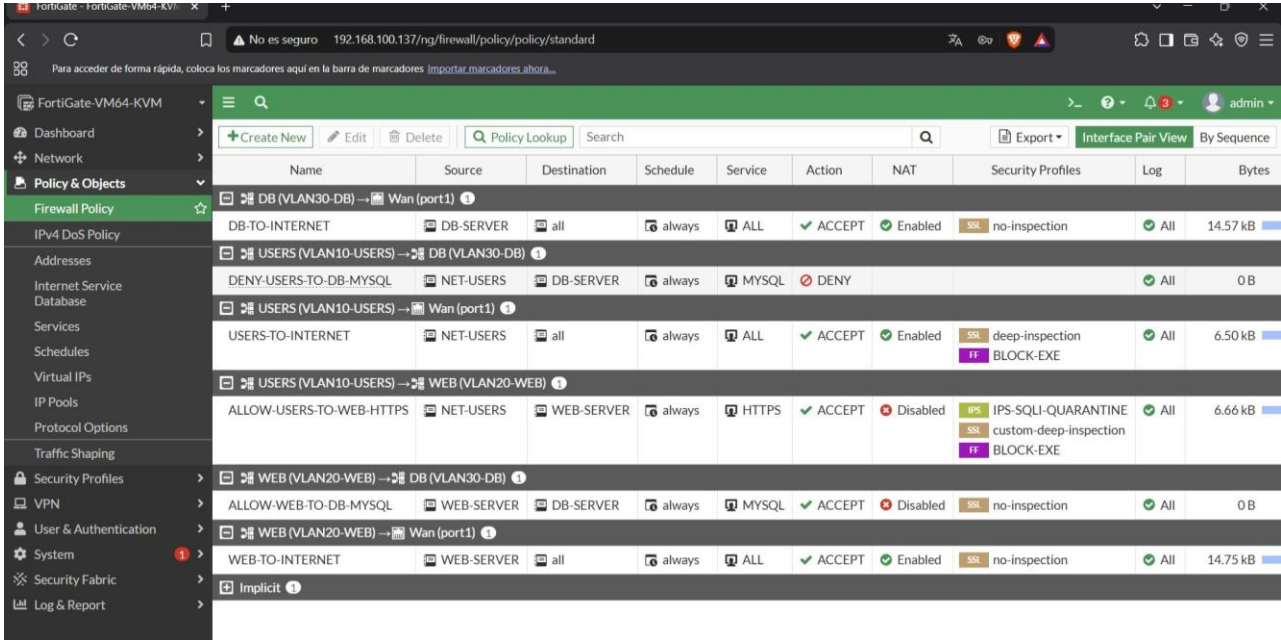


Figura 23. Perfiles de seguridad aplicados a USERS → WEB.

Qué valida	Integración de IPS, File Filter y SSL Inspection dentro de la política HTTPS.
Resultado observado	La política tiene activos IPS-SQLI-QUARANTINE, BLOCK-EXE y custom-deep-inspection.

Cuarentena del atacante

Cuarentena del host atacante

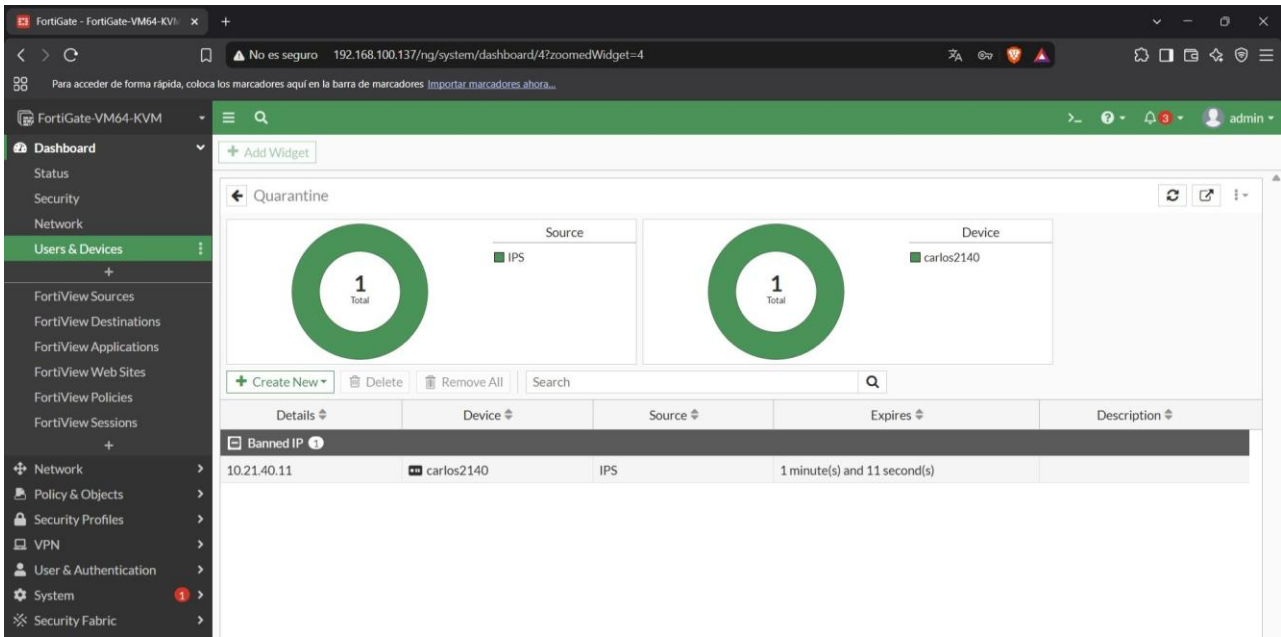
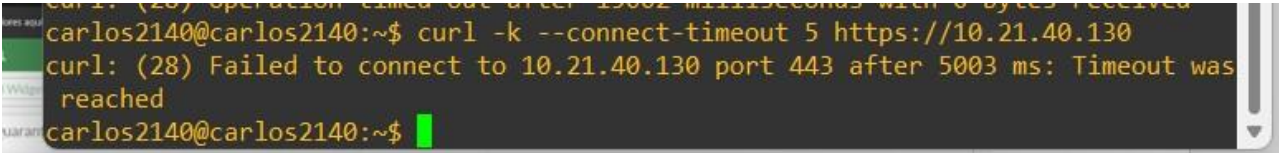


Figura 24. Cuarentena del host atacante.

Qué valida	Respuesta automática posterior a la detección de SQL Injection.
Resultado observado	El host 10.21.40.11 aparece en cuarentena temporal en FortiGate.

Efecto de la cuarentena sobre el atacante



Qué valida	Validación práctica del aislamiento temporal.
Resultado observado	Durante la cuarentena, una solicitud HTTPS normal desde 10.21.40.11 hacia el WEB-SERVER termina en timeout.

Protección DoS / SYN Flood

Detección de anomalía tcp_syn_flood

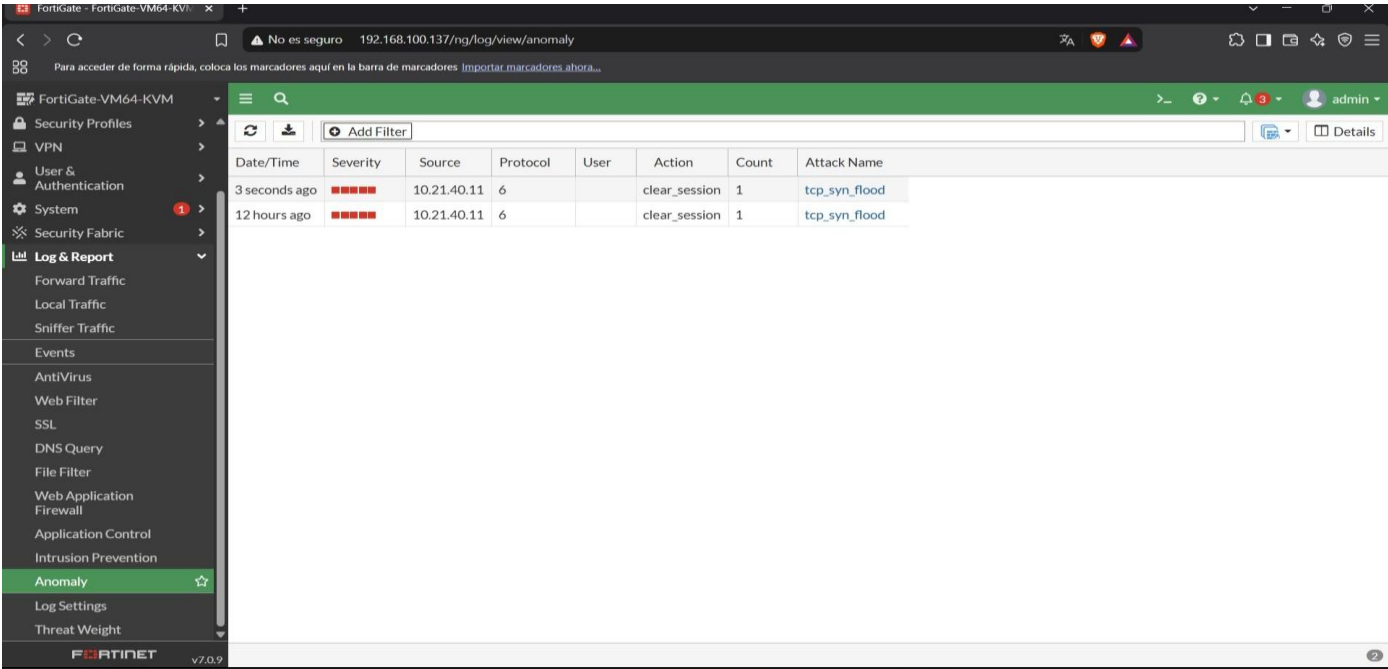
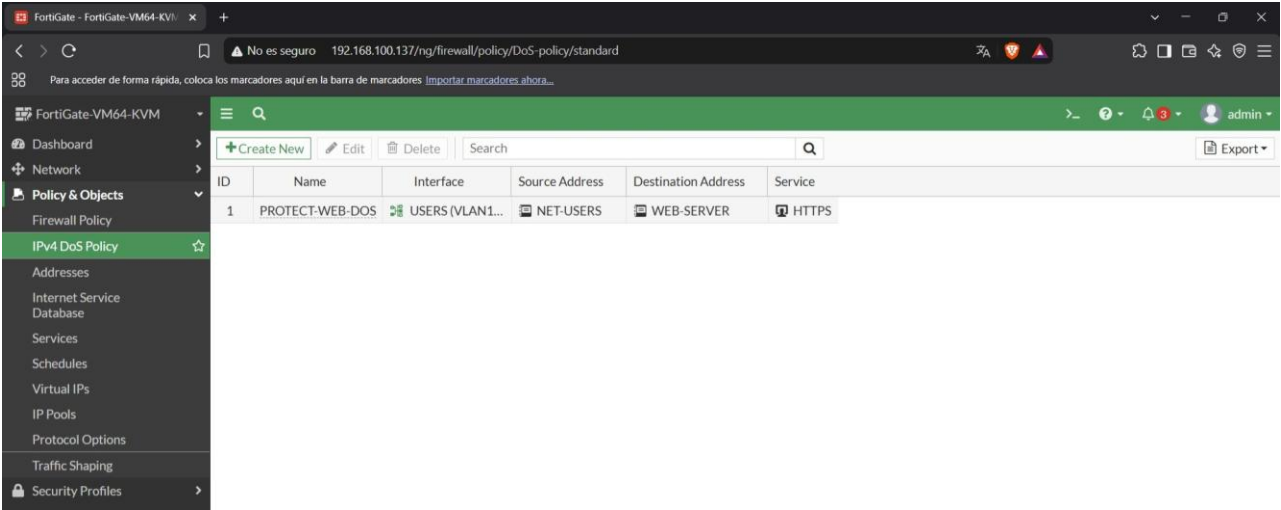


Figura 26. Detección de anomalía tcp_syn_flood.

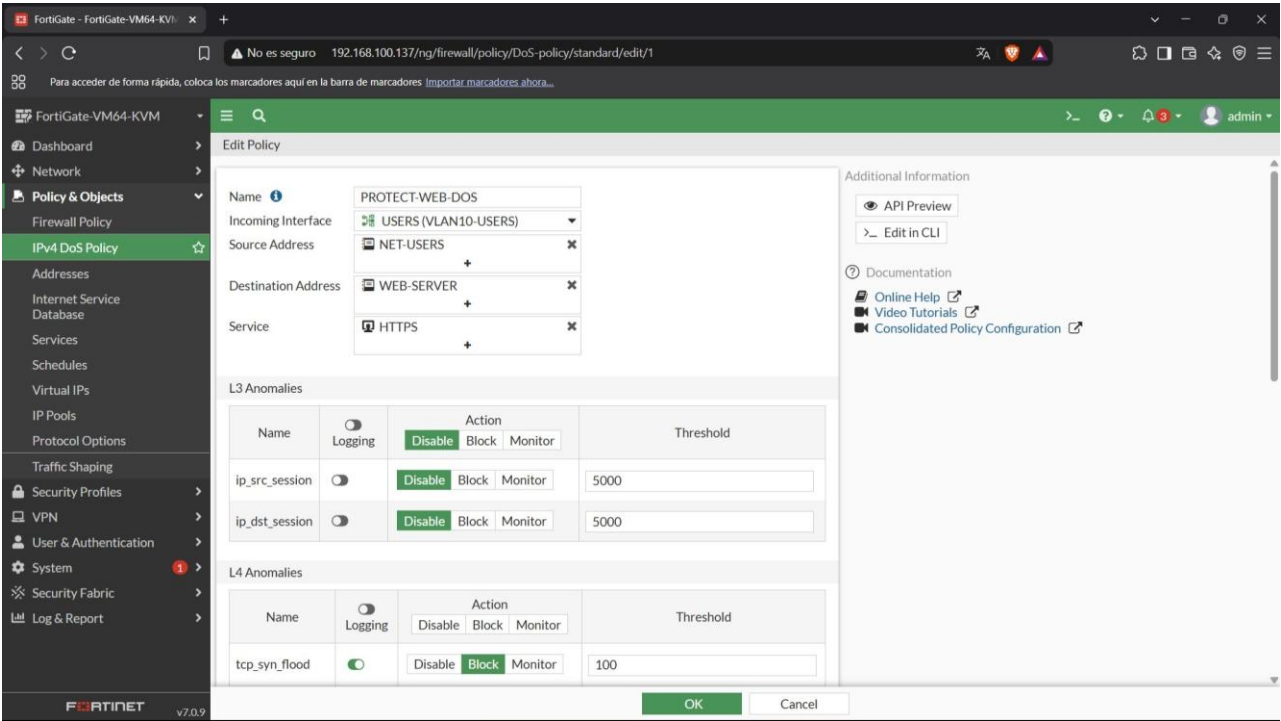
Qué valida	Protección DoS del servicio HTTPS.
Resultado observado	El log de Anomaly registra tcp_syn_flood con el origen del host de prueba.

Política DoS activa



Qué valida	Existencia de la política PROTECT-WEB-DOS.
Resultado observado	La política aparece habilitada para proteger el WEB-SERVER.

Configuración de PROTECT-WEB-DOS



Qué valida	Parámetros de detección/bloqueo para SYN flood.
Resultado observado	Se observa tcp_syn_flood habilitado con acción de bloqueo y umbral configurado.

Conclusión

Las evidencias documentan que el laboratorio aplica segmentación por VLAN, control de acceso entre zonas, salida a Internet, acceso HTTPS al servidor web, restricción del acceso a la base de datos, filtrado de archivos, limitación de ancho de banda, inspección/IPS contra SQL Injection, cuarentena temporal y protección frente a SYN flood. La documentación mantiene separadas las evidencias de configuración y las evidencias de comportamiento observado, facilitando la revisión del proyecto desde GitHub.